

Activepieces 버전.이미지 Digest 고정

불변 이미지 배포, 반복 재현성과 무빌드 롤백 검증 보고서

항목	내용
릴리스	techflow-m0-2026.07.31
검증 시각	2026-07-31T11:38:49Z
환경	Ubuntu 24.04 · linux/amd64 · Activepieces 0.86.3
검증 범위	6 Services · Repeat Deploy · Rollback · Volumes · Security
상태	COMPLETED

이 문서와 구조화 증적에는 비밀번호, API Key, Cookie, Flow Payload, 사용자 식별자와 원문 운영 로그가 포함되지 않는다.

1. 결과 요약

여섯 서비스를 검토된 불변 이미지 조합으로 배포하고, 같은 잠금 반복 배포와 직전 Runtime Lock 롤백을 실제 서버에서 검증했다.

영역	실증	판정
이미지	외부 5개 Tag+Digest · Gateway Image ID	PASS
서비스	6/6 Compose Health	PASS
반복 배포	Runtime Image ID 6/6 동일	PASS
롤백	직전 Runtime Lock · Local-only · No-build	PASS
상태	3 Volumes 이름 보존	PASS
외부 경로	HTTPS 200	PASS
관측	Critical 0 · Warning 0	PASS
보안	Secret 누출 0	PASS

운영 의미

- mutable Tag가 같은 이름으로 다른 이미지를 배포하는 위험을 차단했다.
- 배포 전에 상태 백업과 직전 Runtime Lock이 자동 생성된다.
- 장애 시 Registry나 빌드 환경에 의존하지 않고 로컬 이미지로 복귀한다.

2. 이미지 잠금과 책임 경계

서비스	버전	불변 식별	정책
PostgreSQL	0.8.0-pg14	Registry Digest	Pull
Redis	7.0.7	Registry Digest	Pull
Activepieces App	0.86.3	Registry Digest	Pull
Activepieces Worker	0.86.3	Registry Digest	Pull
Event Gateway	0.1.0	Local Image ID	No-build
Gateway Base	Python 3.12.11	Registry Digest	Build input
Caddy	2.8.4	Registry Digest	Pull

책임

- 개발자는 릴리스 노트, Schema, 보안 영향과 버전을 검토한다.
- 운영자는 승인 잠금으로만 배포하고 Health-Observer를 확인한다.
- TechFlow 스크립트는 잠금 형식, 소스 일치, 이미지와 런타임 상태를 검증한다.
- Activepieces는 Flow 실행 엔진이며 TechFlow의 릴리스 승인과 롤백 정책을 소유하지 않는다.

3. 업그레이드·롤백 드릴

단계	수행	결과
Baseline	Runtime Lock · Volume 목록	Captured
Backup	PostgreSQL Dump · Redis RDB · Manifest	PASS
Locked deploy	Digest Pull · Gateway ID · No-build	PASS
Repeat	같은 잠금 재배포 · 6 ID 비교	IDENTICAL
Rollback	Baseline Lock · Local-only · No-build	PASS
Final	목표 릴리스 재배포	PASS
Volumes	postgres · redis · cache 이름 비교	UNCHANGED

반복 배포와 최종 복귀에서 여섯 Runtime Image ID가 동일했고 세 영속 Volume 이름이 유지됐다.

데이터 호환성

- Schema downgrade가 불가능한 버전은 이미지 롤백만 수행하지 않는다.
- ADR-0003의 격리 복구를 먼저 검증하고 유지보수 창에서 상태와 이미지를 함께 복원한다.

4. Gateway 빌드 재현성 판단

M0의 완료 범위는 같은 승인 이미지를 재현 가능하게 배포·복구하는 것이며, 임의 환경에서 바이트 동일 이미지를 재빌드하는 것까지는 아니다.

- 고정 Base Digest, SOURCE_DATE_EPOCH=0, provenance 비활성화로 no-cache 빌드를 두 번 비교했다.
- COPY 계층과 최종 Image ID가 달라 Source-to-image byte reproducibility는 실패로 판정했다.
- Gateway를 한 번 빌드해 Image ID를 승인하고 배포·롤백에서는 빌드를 금지했다.
- 기대 Image ID가 다르면 배포를 시작하기 전에 Fail Closed 한다.

제품화 Gate

Gate	목적
Approved Registry Digest	호스트 간 같은 Artifact 배포
SBOM	구성 요소와 라이선스·취약점 추적
Image Signature	승인 주체와 무결성 확인
Provenance/Attestation	빌드 입력·환경·과정 증명
Vulnerability Policy	차단 등급 취약점의 배포 방지

5. 통합 검증과 보안

ID	검증	결과
V1	Lock schema and source consistency	PASS
V2	Release lock unit tests	PASS (7)
V3	Independent registry digest checks	PASS
V4	Six locked runtime images	PASS
V5	Six service health checks	PASS
V6	Repeated deployment image ID equality	PASS
V7	Local-only no-build rollback	PASS
V8	Final locked release restoration	PASS
V9	Persistent volume name preservation	PASS
V10	Pre-deployment state backup	PASS
V11	Public HTTPS endpoint	PASS
V12	Observer final state	PASS
V13	Release asset secret scan	PASS

V1-V13 전체 PASS. 런타임 Secret 6종과 릴리스 객체 15개를 대조해 누출 0건을 확인했다.

보안 판정

- 잠금·드릴 증적에는 이미지 식별자, Health와 시각만 기록한다.
- Runtime Lock과 Drill은 root:root 0640으로 제한한다.
- Secret, Cookie, Payload, 사용자 정보와 원문 로그는 기록하지 않는다.

6. 완료 판정과 다음 단계

최종 판정: **VALIDATED**. Issue #18의 같은 구성 재현, 롤백 버전 기록, 운영 문서와 보안 영향 반영 기준을 충족했다.

완료 자산	역할
ADR-0005	잠금·승인·롤백·무효화 기준
image-lock.json	여섯 서비스의 단일 릴리스 기준
배포·롤백 스크립트	사전 백업·No-build·Health-Digest 검증
Runtime Lock-Drill	이전·현재·반복·복구 증적
Runbook	준비·배포·롤백·데이터 비호환 처리
JSON·PDF·PPTX·Manifest	일관된 완료 증적

후속 실행

- Issue #19: GitHub PR Merge Webhook 기반 첫 사내 업무 자동화 Flow
- 제품화 Track: Gateway Registry 게시와 SBOM·서명·취약점 Gate
- 버전 업그레이드 때마다 Schema·환경 변수·보안 영향과 롤백 드릴을 반복한다.

고객 공개 여부는 제품 책임자의 별도 결정이며 구현 완료 판정을 제한하지 않는다.